PatchProof | Technical Assessment Report

Baseline processing, evidence-based remediation and dashboard integration • 26 October 2026

1. Objectives and environment

PatchProof implements a lab-only vulnerability-management workflow: ingest authorized findings, associate CVEs, fetch EPSS/KEV intelligence, calculate reproducible priorities, draft local AI remediation guidance, track fixes, and report outcomes. Assets: DC01 (Windows Server 2022 / AD), WIN-CL (Windows 10), WEB01 (Ubuntu / Apache and Flask), MS2 (Metasploitable2), and KALI-SCAN. Addresses use private `172.16.220.0/24` networking. The organization-like AD domain name is intentionally omitted.

2. Sources and observed baseline

Greenbone severity-classified CSV exports contained 70 MS2, 2 DC01 and 4 WEB01 rows, plus a zero-row workstation export. OWASP ZAP added 4 in-scope WEB01 alert instances. Total imported dataset: 80 rows; this is not an exact count of distinct vulnerabilities. ZAP baseline HTML is retained under `evidence/baseline/`. Nessus authenticated DC01 and WEB01 scan evidence existed in the graphical scanner, but could not be incorporated into the normalized dataset under current export/access constraints.

Environment	Critical	High	Medium	Low	Total
MS2 training host	13	11	40	6	70
DC01 and WEB01 (Greenbone)	0	0	2	4	6
WEB01 (ZAP in-scope)	0	0	2	2	4
Imported total	13	11	44	12	80

3. Normalization and threat intelligence

Python preprocessing outputs `data/unified_findings.csv`, `data/cve_findings.csv`, `data/enriched_cves.csv`, and `data/prioritized_findings.csv`. CVE extraction recorded 125 finding-CVE associations involving 93 unique CVEs. FIRST EPSS supplied values for all 93 at enrichment time. The CISA KEV catalog matched CVE-2012-1823 and CVE-2020-1938 in MS2 data. A KEV match signals known exploitation of a vulnerability class; no actual exploitation of an asset was established.

4. Prioritization methodology

The custom heuristic awards severity points (Critical 45, High 34, Medium 22, Low 10, informational 0), plus 5 times asset criticality (DC01 5, WEB01 4, WIN-CL 3, MS2 1), plus 15 times the maximum linked EPSS probability, plus 15 if any associated CVE is in KEV. Operational priorities: P1 if KEV or score at least 75, P2 at least 55, P3 at least 35, else P4. The deliberately vulnerable MS2 is tracked separately; training status does not constitute formal risk acceptance. Unlinked CVE/EPSS values are marked unavailable, not proven risk-free.

5. AI analysis and database reporting

Local Ollama Qwen3:4b generated 10 schema-constrained JSON analyses with technical risk, business impact, remediation, verification and limitations. All retain pending analyst-review status: sample outputs contained unsupported claims and must not be treated as authoritative evidence. PostgreSQL tables store findings (80), CVE associations (125), and AI assessments (10). Additional `pp_*` tables/views hold asset coverage and verification state. Grafana presents dynamic queries; scanner/enrichment collection requires the separate pipeline.

Verified remediation and outstanding work

WEB01 header fix and independently observed ZAP results

6. Selected remediation

Baseline ZAP identified `Missing Anti-clickjacking Header` on the Flask homepage and `X-Content-Type-Options Header Missing` for its CSS resource. The Flask app was configured via `after_request` to add `X-Frame-Options: DENY` and `X-Content-Type-Options: nosniff`. The header changes are appropriate for the demonstrated non-framed lab page; use of `DENY` should be reviewed against legitimate embedding requirements in other deployments.

Exact finding ID	Fix	Verification
ZAP-c6ed5f83117c110d	Add X-Frame-Options: DENY	Observed in `web01-after-headers.txt`; original alert absent on post-fix ZAP inspection
ZAP-d04e9ebd6c5df4ec	Add X-Content-Type-Options: nosniff	Observed on HTML/CSS responses; original alert absent on post-fix ZAP inspection

7. Verification evidence and tracked outcomes

Saved before/after HTTP response dumps show both security headers newly present with HTTP 200. A fresh ZAP session proxied the homepage and CSS requests and produced `evidence/remediation/web01-zap-rescan.html`; remaining passive alerts were missing Content Security Policy and server version information disclosure. Exact remediation IDs were recorded as verified in PostgreSQL. `pp_exec_exposure` returned 8 requiring review; `pp_exec_remediation` returned 2 verified with evidence out of 10 operational tracked actions. This is evidence for the tested endpoints only.

8. Open findings and constraints

WEB01 has 6 imported findings left after the selected header fixes; DC01 has 2 imported Greenbone findings. WIN-CL zero-row export cannot establish a clean security posture. DC01 authenticated Nessus showed patch-related issues not represented in PostgreSQL; including these would materially change operational prioritization. WSUS was configured and synchronized with GPO settings, but WIN-CL did not register and no successful update deployment was demonstrated. MS2 remains intentionally vulnerable; confirmed removal of internet/NAT connectivity is an outstanding containment requirement.

9. Reproduction and audit trail

Pipeline sequence: `normalize_findings.py` -> `import_zap.py` -> `merge_findings.py` -> `extract_cves.py` -> `enrich_and_prioritize.py` -> `ai_analyze_findings.py` -> `import_postgres.py`. Remediation records are managed by `finish_patchproof.py`. Source raw exports, run-level evidence, and dashboard JSON should be retained, with credentials and identifying strings removed before publication.

10. Definition of delivered MVP

Completed: evidence ingestion from two scanners, official exploitation-intelligence enrichment, reproducible custom scoring, local AI narrative generation, PostgreSQL and Grafana integration, and two verified fixes. Not claimed complete: comprehensive authenticated Windows assessment, Nessus ingestion, all-asset remediation, signed risk acceptances, continuous scheduled scanning, or production hardening. No claims of exploitation or confirmed compromise are made.